

The logo consists of a blue rounded square containing the white text "CTO".

CTO

Regulatory & Standards Assessment Tool

Screen tour — every part of the application

CTO Consulting

Reference organisation: National Insurance Disability Agency

Discovery example: Commonwealth Bank of Australia

Captured 29 September 2026

Contents

Screens captured from the running application. The assessment results shown (8 requirements) are example entries made for illustration.

1	Dashboard
2	Organisations
3	Discover obligations — step 1: organisation name
4	Discover obligations — step 2: profile
5	Discover obligations — step 3: applicable sources
6	Discover obligations — step 4: generate register
7	Dashboard — newly discovered organisation
8	Obligations register
9	Obligation detail
10	Policy requirements
11	Policy requirement detail
12	Control assessment (1 of 2)
13	Control assessment (2 of 2)
14	Assessment report
15	Traceability — trace explorer
16	Traceability — matrix
17	Traceability — coverage heatmap
18	Policy author
19	Policy author — policy requirements section
20	Regulatory calendar — month
21	Regulatory calendar — agenda
22	Register explorer
23	Mobile view

1. Dashboard (continued 1/2)

Summary of every obligation discovered for the selected organisation: sources, obligations, requirements, compliance score and upcoming deadlines.

CTO Consulting

REGULATORY ASSESSMENT

OVERVIEW

Dashboard

Organisations

Discover obligations

REGISTER

Obligations

Policy requirements

Traceability

Register explorer

ASSURANCE

Control assessment

Assessment report

Regulatory calendar

AUTHORING

Policy author

AI research: rules engine

© CTO Consulting · ctoconsulting.com.au

ORGANISATION

National Insurance Disability Agency

+ New organisation

REGULATORY OBLIGATIONS DASHBOARD

National Insurance Disability Agency

Commonwealth corporate entity (statutory authority) · Government services & administration, Disability services / NDIS · National

105

APPLICABLE SOURCES

3,634

OBLIGATIONS

240

POLICY REQUIREMENTS

14

TARGET POLICIES

75%

COMPLIANCE SCORE

30

DEADLINES IN 90 DAYS

Obligations by applicability

How each obligation applies to this organisation

3,634 obligations

Mandatory 3,335

Conditional 192

Recommended 107

Control assessment

8 of 240 requirements assessed (3%)

Assess

75%

Compliance score

Compliant 4

Largely compliant 2

Partially compliant 1

Non-compliant 1

Not assessed 232

Upcoming regulatory deadlines

Calendar

1 overdue exemption or remediation item

2026-09-30

Commonwealth fraud and corruption census return (AIC)...

2026-09-30

NAA Check-up information management survey (indicative)

2026-09-30

PSPF annual security report to Home Affairs and Minister...

2026-10-15

Annual report to responsible Minister (PGPA Act s46)

2026-10-15

Quarterly external ASV vulnerability scan (PCI DSS 11.3....

2026-10-28

FOI statistics return to OAIC (indicative)

2026-10-30

Remediation due — NDIA-ICT-GOV-002: Accountable Authority...

+ 4 event-driven deadlines (e.g. breach and incident notification).

Obligations by source

Top 12 of 105 sources — select a bar to filter the register

Information Security Manual (ISM)

1110

Protective Security Policy Frame...

932

Essential Eight Maturity Model

99

Privacy Act 1988 and Australian...

94

PGPA Act 2013

87

NDIS Act 2013

83

Archives Act 1983

70

Hosting Certification Framework...

49

Freedom of Information Act 1982

49

Commonwealth Procurement R...

45

Security of Critical Infrastructur...

43

Privacy Code

42

Mandatory

Conditional

Recommended

Obligations by target policy

Suggested policy that gives effect to each obligation

NDIA ICT Cyber Security Policy

1381

NDIA ICT Insider Threat and Ris...

243

ICT Digital Experience Policy

219

NDIA ICT Identity Management ...

214

NDIA ICT Technology Enabled Pr...

207

NDIA ICT Service Management ...

202

NDIA ICT Infrastructure Manage...

194

NDIA ICT Technology Portfolio Pl...

191

ICT Authorisation and Accrediati...

179

ICT Agency and Scheme Applic...

170

NDIA ICT Integration Policy

155

ICT Acceptable Use Policy

135

NDIA ICT Disaster Recovery Policy

110

ICT Governance Policy

34

Obligations by publisher / regulator

Australian Signals ...

1220

Department of Ho...

896

Digital Transformat...

261

Federal Register of...

246

Department of Fina...

186

Attorney-General's...

121

Protective Security...

119

Office of the Austr...

86

National Archives o...

63

Requirements by priority

Critical

125

High

109

Medium

6

FINDINGS

4

Partial, largely or non-compliant

EXEMPTIONS

3

Recorded in the register

ISM CONTROLS

261

Linked to requirements

POLICY DOCS

0

of 14 authored

1. Dashboard (continued 2/2)

National Archives of Australia

Office of the Australian Information Commissioner

43

Applicable obligation sources				
Legislation, mandatory policies and standards discovered for this organisation			Filter sources...	
SOURCE	APPLICABILITY	WHY IT APPLIES	PUBLISHER	OBLIGATIONS
Information Security Manual (ISM)	Mandatory	Commonwealth entity — ISM controls are applied through the PSPF	Australian Signals Directorate	1110
Protective Security Policy Framework (PSPF) Release 2025	Mandatory	Commonwealth entity — PSPF requirements apply (mandatory for non-corporate entities; applied to corporate entities by direction and adopted in policy)	Department of Home Affairs	932
Essential Eight Maturity Model	Mandatory	Commonwealth entities must implement the Essential Eight (PSPF requirement)	Australian Signals Directorate / Australian Cyber Security Centre	99
Privacy Act 1988 and Australian Privacy Principles	Mandatory	Commonwealth agency — bound by the Australian Privacy Principles	Office of the Australian Information Commissioner (OAIC)	94
PGPA Act 2013	Mandatory	Public Governance, Performance and Accountability Act applies to all Commonwealth entities	Federal Register of Legislation	87
NDIS Act 2013	Mandatory	Entity administers or regulates the NDIS under the NDIS Act	Federal Register of Legislation	83
Archives Act 1983	Mandatory	Commonwealth records must be managed under the Archives Act	National Archives of Australia	70
Hosting Certification Framework (HCF) / Secure Cloud	Mandatory	Commonwealth entities must use certified hosting for sensitive data	Department of Home Affairs	49
Freedom of Information Act 1982	Mandatory	FOI Act gives the public a right to access Commonwealth documents	Office of the Australian Information Commissioner / Federal Register of Legislation	49
Commonwealth Procurement Rules and PGPA procurement controls	Mandatory	Commonwealth Procurement Rules apply to procurement by Commonwealth entities	Department of Finance	45
Privacy Code	Mandatory	Australian Government Agencies Privacy Code applies to Commonwealth agencies	Office of the Australian Information Commissioner	42

2. Organisations

All organisations under assessment, profile, Excel export, backup/restore and register data-quality checks.

CTO Consulting

REGULATORY ASSESSMENT

OVERVIEW

Dashboard

Organisations

Discover obligations

REGISTER

Obligations

Policy requirements

Traceability

Register explorer

ASSURANCE

Control assessment

Assessment report

Regulatory calendar

AUTHORING

Policy author

AI research: rules engine

© CTO Consulting - ctoconsulting.com.au

ORGANISATION

National Insurance Disability Agency

+ New organisation

ORGANISATIONS

Organisations under assessment

Each organisation has its own obligations register, policy requirements, control assessments, policy documents and calendar. Data is stored in this browser — use Backup to move or share it.

Restore backup+ New organisation

Reference registerSelected

National Insurance Disability Agency

NDIA · Commonwealth corporate entity (statutory authority)

105 sources 3,634 obligations

240 requirements

Source: NDIA_ICT_Policy_Requirements_Register_v0.48.xlsx

Open

Profile — National Insurance Disability Agency

Drives which obligations apply

Organisation type	Commonwealth corporate entity (statutory authority)
Industries	Government services & administration, Disability services / NDIS
Jurisdictions	NSW, VIC, QLD, WA, SA, TAS, ACT, NT
Characteristics	Annual turnover above \$3 million; Consolidated revenue above \$100 million; Collects or holds personal information; Collects or holds health information / provides a health service; Collects tax file numbers (e.g. as an employer); Holds security-classified government information; Provides services to children or young people; Delivers digital services to the public (web / app / portal); Develops or uses AI / automated decision-making; Uses public cloud or outsourced hosting; Participates in the Australian Government Digital ID System or uses DVS/FVS
Assessment progress	8 of 240 requirements assessed · score 75%

Loaded from NDIA_ICT_Policy_Requirements_Register_v0.48.xlsx: 240 requirements, 3,634 obligations, 3 exemptions, 218 PSPF requirements and all 53 worksheets (see Register explorer).

Export & backup

National Insurance Disability Agency

Export register to Excel

Requirements (41 attributes), Obligations, Exemptions, Applicable Sources and Control Assessment sheets, in the same layout as the source register.

Download backup (.json)

Profile, register, assessments and authored policies — restore on another device with "Restore backup".

Register data quality

Medium

 12 requirement(s) carry a Policy Number that does not match their Requirement ID policy code (e.g. NDIA-ICT-CYB-002 → NDIA-POL-ICT-DRP-001). The tool groups them by Requirement ID.

Low

 Policy title typo: "ICT Authorisation and Accrediatobn Policy".

3. Discover obligations — step 1: organisation name

Enter the organisation name, or import an existing register workbook.

CTO Consulting
REGULATORY
ASSESSMENT

OVERVIEW

- Dashboard
- Organisations
- Discover obligations

REGISTER

- Obligations
- Policy requirements
- Traceability
- Register explorer

ASSURANCE

- Control assessment
- Assessment report
- Regulatory calendar

AUTHORING

- Policy author

AI research: rules engine
© CTO Consulting - ctoconsulting.com.au

ORGANISATIONNational Insurance Disability Agency

+ New organisation

DISCOVERY

Discover regulatory obligations

Enter an organisation, confirm its profile, and the tool identifies every applicable law, mandatory policy and standard, then builds its obligations register and policy requirements with suggested target policies.

1 Organisation

2 Profile

3 Applicable obligations

4 Generate register

Organisation name

The profile is inferred from the name and can be refined on the next step

Organisation name

Commonwealth Bank of Australia

Continue

Try: "Commonwealth Bank of Australia", "Sydney Water", "Department of Health Victoria", "Acme Software Pty Ltd".

Already have a register?

Import a workbook in the Policy Requirements Register format

Upload an .xlsx with a **Requirements** sheet (41 attributes) and an **Obligations** sheet. Everything is loaded against the organisation name entered on the left (or the file name).

Import workbook (.xlsx)

4. Discover obligations — step 2: profile

Profile inferred from the name; every answer can be refined. “Research with Claude” appears when an API key is configured.

CTO Consulting
REGULATORY
ASSESSMENT

OVERVIEW

- Dashboard
- Organisations
- Discover obligations

REGISTER

- Obligations
- Policy requirements
- Traceability
- Register explorer

ASSURANCE

- Control assessment
- Assessment report
- Regulatory calendar

AUTHORING

- Policy author

AI research: rules engine
© CTO Consulting · ctoconsulting.com.au

ORGANISATIONNational Insurance Disability Agency

+ New organisation

DISCOVERY

Discover regulatory obligations

Enter an organisation, confirm its profile, and the tool identifies every applicable law, mandatory policy and standard, then builds its obligations register and policy requirements with suggested target policies.

1 Organisation

2 Profile

3 Applicable obligations

4 Generate register

Profile — Commonwealth Bank of Australia

Inferred from the name (matched “Commonwealth Bank”). Review every answer: applicability depends on it.

AI research not configured

Short name / acronym (used in IDs and documents)

Organisation type

CBA

ASX-listed company

Industries

Government services & administration

Disability services / NDIS

Health care & medical

Aged care

Banking (ADI)

Insurance

Superannuation

Financial services, lending & payments

Energy (electricity, gas, liquid fuels)

Water & sewerage

Telecommunications

Transport & logistics

Education

Child care & community services

Retail & e-commerce

Technology / SaaS / data services

Defence & defence industry

Mining, resources & agriculture

Professional services

Australian jurisdictions of operation

International operations

NSW

VIC

QLD

WA

SA

TAS

ACT

NT

European Union

United Kingdom

United States

New Zealand

Scale

Information

Services

Technology

Regulatory

☒ Annual turnover above \$3 million

☒ Consolidated revenue above \$100 million

☒ Large entity for climate reporting (e.g. 250+ employees or \$50m+ revenue)

☒ Collects or holds personal information

☐ Collects or holds health information / provides a health service

☒ Collects tax file numbers (e.g. as an employer)

☐ Holds security-classified government information

☐ Provides services to children or young people

☒ Delivers digital services to the public (web / app / portal)

☒ Stores, processes or transmits payment card data

☒ Develops or uses AI / automated decision-making

☒ Uses public cloud or outsourced hosting

☒ Owns or operates a critical infrastructure asset (SOCI)

☒ APRA-regulated entity

☒ Holds an AFS or credit licence (ASIC-regulated)

☒ AUSTRAC reporting entity (AML/CTF)

☒ Consumer Data Right data holder / accredited recipient

☒ Participates in the Australian Government Digital ID System or uses DVS/FVS

☐ Contracted service provider to the Commonwealth

☐ Registered NDIS provider

☐ Listed on a US exchange (SEC registrant)

Back

Discover applicable obligations →

5. Discover obligations — step 3: applicable sources (continued 1/2)

Applicable legislation, mandatory policies and standards with the reason each applies.

CTO Consulting
REGULATORY
ASSESSMENT

OVERVIEW

- Dashboard
- Organisations
- Discover obligations

REGISTER

- Obligations
- Policy requirements
- Traceability
- Register explorer

ASSURANCE

- Control assessment
- Assessment report
- Regulatory calendar

AUTHORING

- Policy author

AI research: rules engine
© CTO Consulting · ctoconsulting.com.au

DISCOVERY

Discover regulatory obligations

Enter an organisation, confirm its profile, and the tool identifies every applicable law, mandatory policy and standard, then builds its obligations register and policy requirements with suggested target policies.

Organisation

Profile

3 Applicable obligations

4 Generate register

MANDATORY

34

A legal or binding policy obligation that applies to the organisation.

CONDITIONAL

5

Applies where the organisation undertakes the triggering activity —

RECOMMENDED

23

Better-practice standard or guidance adopted voluntarily.

SELECTED

61 sources

718 obligations

ORGANISATION

National Insurance Disability Agency

+ New organisation

Search sources...

Select all

Mandatory & conditional only

Mandatory 34 sources

SOURCE	WHY IT APPLIES	PUBLISHER	OBLIGATIONS
☒ Privacy Act 1988 and Australian Privacy Principles	APP entity (turnover above \$3m, health service provider or contracted to the Commonwealth)	Office of the Australian Information Commissioner (OAIC)	94
☒ Security of Critical Infrastructure Act 2018	Responsible entity for a critical infrastructure asset — SOCI obligations apply	Department of Home Affairs / Cyber and Infrastructure Security Centre	43
☒ Disability Discrimination Act 1992	Goods, services and facilities (including digital) must not discriminate on the basis of disability	Australian Human Rights Commission / Federal Register of Legislation	36
☒ Cyber Security Act 2024 and Cyber Security (Ransomware Payment Reporting) Rules 2025	Reporting business entity (turnover above \$3m) — ransomware payments must be reported within 72 hours	Department of Home Affairs	27
☒ Notifiable Data Breaches Scheme	Eligible data breaches must be notified to the OAIC and affected individuals	Office of the Australian Information Commissioner	25
☒ Consumer Data Right information security and conformance	CDR participant — Schedule 2 information security controls apply	Consumer Data Right / CDR.gov.au	12
☒ PCI DSS v4.0.1	Card payments are processed — PCI DSS is required by card schemes and acquirers	PCI Security Standards Council	12
☒ Criminal Code Act 1995	Computer offences and misuse of information are criminal offences	Attorney-General's Department / Federal Register of Legislation	11
☒ Work Health and Safety Act 2011	Persons conducting a business or undertaking owe WHS duties	Comcare / Federal Register of Legislation	11
☒ TIA Act 1979	Interception of and access to communications is regulated by the TIA Act	Attorney-General's Department / Federal Register of Legislation	10
☒ APRA CPS 234 Information Security Catalogue	APRA-regulated entity — CPS 234 is binding	Australian Prudential Regulation Authority	9
☒ APRA CPS 230 Operational Risk Management Catalogue	APRA-regulated entity — CPS 230 is binding from 1 July 2025	Australian Prudential Regulation Authority	7
☒ Surveillance Laws	State and territory surveillance devices laws regulate monitoring	Relevant Commonwealth, state and territory legislation registers	7
☒ Australian Privacy Principle	APP entity — Australian Privacy Principles apply	OAIC	6
☒ Copyright Act 1968 Cth	Use of copyright material through ICT must comply with the Copyright Act	Federal Register of Legislation	6
☒ AML/CTF Act 2006 and Rules Catalogue	AUSTRAC reporting entity providing designated services	AUSTRAC	5
☒ ASX Listing Rules and Corporate Governance Principles Catalogue	ASX-listed entity	ASX Limited	4
☒ Corporations Act 2001 — directors' duties and records Catalogue	Company registered under the Corporations Act	Australian Securities and Investments Commission	4
☒ Fair Work Act 2009 Cth	National workplace relations system employer	Federal Register of Legislation	4

5. Discover obligations — step 3: applicable sources (continued 2/2)

	☒ Fair Work Act 2009 (Cth)	National workplace relations system employer	Federal Register of Legislation	4
	☒ Privacy Amendment 2024	Privacy and Other Legislation Amendment Act 2024 amends APP entity obligations	Federal Register of Legislation	4
	☒ TSM Rules	Tax file number recipients must comply with the	Office of the Australian Information	4

6. Discover obligations — step 4: generate register

Preview of the obligations register and policy requirements, grouped by suggested target policy.

CTO Consulting
REGULATORY
ASSESSMENT

OVERVIEW

- Dashboard
- Organisations
- Discover obligations

REGISTER

- Obligations
- Policy requirements
- Traceability
- Register explorer

ASSURANCE

- Control assessment
- Assessment report
- Regulatory calendar

AUTHORING

- Policy author

AI research: rules engine
© CTO Consulting - ctoconsulting.com.au

DISCOVERY

Discover regulatory obligations

Enter an organisation, confirm its profile, and the tool identifies every applicable law, mandatory policy and standard, then builds its obligations register and policy requirements with suggested target policies.

Organisation

Profile

Applicable obligations

4 Generate register

ORGANISATIONNational Insurance Disability Agency

+ New organisation

The register for **Commonwealth Bank of Australia** will contain **718** obligations from **61** sources, consolidated into **141** policy requirements across **14** suggested target policies. Every requirement is created with the full set of register attributes (control objective, threat, implementation guidance, RACI, verification, evidence, audit and review cycles), tailored to the organisation.

SUGGESTED TARGET POLICY	POLICY NUMBER	REQUIREMENTS
ICT Acceptable Use Policy	CBA-POL-ICT-AUP-001	20
Identity Management Policy	CBA-POL-ICT-IDM-001	15
ICT Authorisation and Accreditation Policy	CBA-POL-ICT-AAP-001	13
Cyber Security Policy	CBA-POL-ICT-CYB-001	13
ICT Infrastructure Management Policy	CBA-POL-ICT-INF-001	11
Insider Threat and Risk Policy	CBA-POL-ICT-INT-001	11
ICT Integration Policy	CBA-POL-ICT-ING-001	10
ICT Service Management Policy	CBA-POL-ICT-SVM-001	10
ICT Disaster Recovery Policy	CBA-POL-ICT-DRP-001	9
Digital Experience Policy	CBA-POL-ICT-DEP-001	8
Technology Enabled Projects Policy	CBA-POL-ICT-TEP-001	7
Business Applications Policy	CBA-POL-ICT-ASA-001	6
Technology Portfolio Planning Policy	CBA-POL-ICT-TPP-001	6
ICT Governance Policy	CBA-POL-ICT-GOV-001	2

Back

Create organisation

7. Dashboard — newly discovered organisation

Dashboard for the Commonwealth Bank of Australia generated by the discovery engine.

CTO Consulting

REGULATORY ASSESSMENT

OVERVIEW

Dashboard

Organisations

Discover obligations

REGISTER

Obligations

Policy requirements

Traceability

Register explorer

ASSURANCE

Control assessment

Assessment report

Regulatory calendar

AUTHORING

Policy author

AI research: rules engine

© CTO Consulting · ctoconsulting.com.au

ORGANISATION

Commonwealth Bank of Australia

+ New organisation

REGULATORY OBLIGATIONS DASHBOARD

Commonwealth Bank of Australia

ASX-listed company · Banking (ADI), Financial services, lending & payments, Insurance · NSW

61

APPLICABLE SOURCES

718

OBLIGATIONS

141

POLICY REQUIREMENTS

14

TARGET POLICIES

—

COMPLIANCE SCORE

5

DEADLINES IN 90 DAYS

Obligations by applicability

How each obligation applies to this organisation

718 obligations

Mandatory 379

Conditional 60

Recommended 279

Control assessment

0 of 141 requirements assessed (0%)

Assess

Compliance score

Not assessed 141

Upcoming regulatory deadlines

Calendar

2026-10-15

Quarterly external ASV vulnerability scan (PCI DSS 11.3....

2026-10-31

Annual financial report lodgement (large proprietary companies)...

2026-11-30

Annual PCI DSS assessment (ROC / SAQ and AOC) (indicative)

2026-12-10

Automated decision-making transparency obligations...

2026-12-10

Children's Online Privacy Code registration deadline (OAIC)

2026-12-29

Control audit — Business Applications Policy (2...

2026-12-29

Control audit — Cyber Security Policy (5 requirements)

+ 6 event-driven deadlines (e.g. breach and incident notification).

Obligations by source

Top 12 of 61 sources — select a bar to filter the register

Essential Eight Maturity Model

99

Privacy Act 1988 and Australian...

94

Security of Critical Infrastructur...

43

Disability Discrimination Act 1992

36

Digital ID Act 2024

32

Responsible AI

32

Cyber Security Act 2024 and Cy...

27

Notifiable Data Breaches Scheme

25

OWASP ASVS and OWASP SAMM

19

CIS Critical Security Controls v8.1

18

Information Security Manual (IS...

16

Electronic Transactions Act 1999

14

Mandatory

Conditional

Recommended

Obligations by target policy

Suggested policy that gives effect to each obligation

Cyber Security Policy

163

Identity Management Policy

74

ICT Acceptable Use Policy

70

ICT Authorisation and Accredita...

67

Insider Threat and Risk Policy

55

ICT Service Management Policy

52

Digital Experience Policy

44

ICT Infrastructure Management ...

38

Business Applications Policy

37

ICT Integration Policy

36

ICT Disaster Recovery Policy

30

Technology Enabled Projects Pol...

29

Technology Portfolio Planning P...

20

ICT Governance Policy

3

Obligations by publisher / regulator

Requirements by priority

FINDINGS

0

EXEMPTIONS

0

8. Obligations register

Obligations in the format of the register’s Obligations tab, with filters and CSV export.

CTO Consulting
REGULATORY
ASSESSMENT

OVERVIEW

- Dashboard
- Organisations
- Discover obligations

REGISTER

- Obligations
- Policy requirements
- Traceability
- Register explorer

ASSURANCE

- Control assessment
- Assessment report
- Regulatory calendar

AUTHORING

- Policy author

AI research: rules engine
© CTO Consulting - ctoconsulting.com.au

ORGANISATIONNational Insurance Disability Agency

+ New organisation

OBLIGATIONS REGISTER

Obligations — NDIA

Every obligation applicable to National Insurance Disability Agency, populated in the format of the register’s Obligations tab and mapped to the policy requirement and target policy that gives effect to it.

Export CSV

Search ID, reference, description...All sources (105)All target policiesAll applicability

All publishers

OBLIGATION ID	OBLIGATION	DESCRIPTION	REQUIREMENT	TARGET POLICY	APPLICABILITY
ARC-04	Archives Act 1983 Archives Act 1983 - Agency responsibilities	The Act makes agencies responsible for destruction, transfer or alteration of Commonwealth records subject to National...	NDIA-ICT-AAP-014	ICT Authorisation and Accrediation Policy	Mandatory
ARC-05	Archives Act 1983 Archives Regulations - Written information about records events	The Regulations require agencies to keep written information about destruction, transfer, damage or alteration of Commonwealth records in their...	NDIA-ICT-AAP-014	ICT Authorisation and Accrediation Policy	Mandatory
ARC-06	Archives Act 1983 NAA guidance - Data and datasets are Commonwealth records	Data and datasets retained in business systems, like other information created or received in connection with Australian Government business,...	NDIA-ICT-AAP-004	ICT Authorisation and Accrediation Policy	Mandatory
ARC-07	Archives Act 1983 NAA guidance - Identify digital records in business systems	Identifying digital records created by business systems is the essential first step in determining and applying information management strategies.	NDIA-ICT-AAP-004	ICT Authorisation and Accrediation Policy	Mandatory
ARC-08	Archives Act 1983 NAA Information Management Standard - Store and preserve...	Business information should be stored securely and preserved in a usable condition for as long as required for business needs and community access.	NDIA-ICT-AAP-014	ICT Authorisation and Accrediation Policy	Mandatory
ARC-09	Archives Act 1983 NAA guidance - Metadata and supporting documentation	Managing data and datasets requires associated metadata and documentation needed to understand and use the dataset.	NDIA-ICT-AAP-014	ICT Authorisation and Accrediation	Mandatory

9. Obligation detail

All obligation attributes and the mapped policy requirement(s).

CTO Consulting

REGULATORY ASSESSMENT

OVERVIEW

Dashboard

Organisations

Discover obligations

REGISTER

Obligations

Policy requirements

Traceability

Register explorer

ASSURANCE

Control assessment

Assessment report

Regulatory calendar

AUTHORING

Policy author

AI research: rules engine

© CTO Consulting · ctoconsulting.com.au

ORGANISATION

National Insurance Disab

OBLIGATIONS REGISTER

Obligations — NDIA

Every obligation applicable to National Insu

Obligations tab and mapped to the policy n

Search ID, reference, description...

All publishers

OBLIGATION ID	OBLIGATION
ARC-04	Archives Act 1983 Archives Act 1983 - Agency responsibilities
ARC-05	Archives Act 1983 Archives Regulations - Writing information about records
ARC-06	Archives Act 1983 NAA guidance - Data and e are Commonwealth record
ARC-07	Archives Act 1983 NAA guidance - Identify dig records in business system
ARC-08	Archives Act 1983 NAA Information Managem Standard - Store and prese
ARC-09	Archives Act 1983 NAA guidance - Metadata supporting documentation

OBLIGATION ARC-04

Archives Act 1983 - Agency responsibilities

NDIA Policy Number

NDIA-POL-ICT-AAP-001

Obligation ID

ARC-04

Obligation Name

Archives Act 1983

Obligation Reference

Archives Act 1983 - Agency responsibilities

Obligation Description

The Act makes agencies responsible for destruction, transfer or alteration of Commonwealth records subject to National Archives authorisation, transfer of Commonwealth archives and following records management requirements.

Applicability to the NDIA

Applies because the NDIA creates, stores, retrieves and disposes of Commonwealth records in ICT systems. Means for the NDIA: The Act makes agencies responsible for destruction, transfer or alteration of Commonwealth records subject to National Archives authorisation, transfer of Commonwealth archives and following records management requirements.

Applicability level

Mandatory

Obligation Source

Information management legislation

Publisher

National Archives of Australia

Obligation Type

Legislation guidance

Source URLs

https://www.naa.gov.au/information-management/information-management-legislation

Mapped policy requirements

NDIA-ICT-AAP-014 — Records, metadata, retention and secure disposal

Suggested target policy: ICT Authorisation and Accrediatobn Policy (NDIA-POL-ICT-AAP-001)

Requirement

Trace

10. Policy requirements

Requirements grouped by suggested target policy, with priority and assessment status.

CTO Consulting
REGULATORY
ASSESSMENT

OVERVIEW

- Dashboard
- Organisations
- Discover obligations

REGISTER

- Obligations
- Policy requirements**
- Traceability
- Register explorer

ASSURANCE

- Control assessment
- Assessment report
- Regulatory calendar

AUTHORING

- Policy author

AI research: rules engine
© CTO Consulting - ctoconsulting.com.au

ORGANISATIONNational Insurance Disability Agency

+ New organisation

POLICY REQUIREMENTS

Policy requirements — NDIA

Requirements consolidate the obligations into enforceable policy statements, each with a suggested target policy and the full set of register attributes.

Export CSV

AUP25
ICT Acceptable Use Policy

ASA12
ICT Agency and Scheme Applications

AAP16
ICT Authorisation and Accrediation Policy

DEP16
ICT Digital Experience Policy

GOV34
ICT Governance Policy

CYB13
NDIA ICT Cyber Security Policy

DRP11
NDIA ICT Disaster Recovery Policy

IDM18
NDIA ICT Identity Management Policy

INF16
NDIA ICT Infrastructure...

INT18
NDIA ICT Insider Threat and Risk Policy

ING16
NDIA ICT Integration Policy

SVM15
NDIA ICT Service Management Policy

TEP15
NDIA ICT Technology Enabled Projects...

TPP15
NDIA ICT Technology Portfolio Planning...

Search requirements...

All target policies

All priorities

Requirement ID	Requirement	Suggested Target Policy	Priority	Obligations	Assessment
NDIA-ICT-GOV-001	Compliance with WoAG Protective Security Directions The NDIA shall ensure that the Accountable Authority complies with all Protective Security Directions issued under the Protective Security...	ICT Governance Policy NDIA-POL-ICT-GOV-001	Critical	1	Compliant
NDIA-ICT-GOV-002	Accountable Authority Ministerial Accountability for Protective Security The NDIA shall ensure that the Accountable Authority is answerable to	ICT Governance Policy NDIA-POL-ICT-	Critical	1	Partially compliant

11. Policy requirement detail

All 41 register attributes for a requirement plus its mapped obligations.

CTO Consulting

REGULATORY ASSESSMENT

OVERVIEW

Dashboard

Organisations

Discover obligations

REGISTER

Obligations

Policy requirements

Traceability

Register explorer

ASSURANCE

Control assessment

Assessment report

Regulatory calendar

AUTHORING

Policy author

AI research: rules engine

© CTO Consulting · ctoconsulting.com.au

ORGANISATION

National Insurance Disab

POLICY REQUIREMENTS

Policy requirements —

Requirements consolidate the obligations in policy and the full set of register attributes.

AUP25

ICT Acceptable Use Policy

ASA12

ICT Agency and Scheme Applic

DRP11

NDIA ICT Disaster Recovery Policy

IDM18

NDIA ICT Ident Management P

TEP15

NDIA ICT Technology Enabled Projects...

TPP15

NDIA ICT Techn Portfolio Plann

Search requirements...

Requirement ID	Requirement
NDIA-ICT-GOV-001	Compliance with W
NDIA-ICT-GOV-002	Accountable Autho

NDIA-ICT-GOV-001

Compliance with WoAG Protective Security Directions

Assess

Trace

X

Suggested target policy: ICT Governance Policy (NDIA-POL-ICT-GOV-001)

Compliant

IDENTIFICATION

Requirement ID	NDIA-ICT-GOV-001
Target Policy Title	ICT Governance Policy
Policy Number	NDIA-POL-ICT-GOV-001
Policy Domain	Strategy, Architecture, and Governance
Policy Section / Clause	WoAG Protective Security Roles

REQUIREMENT CORE

Requirement Title	Compliance with WoAG Protective Security Directions
Obligation Description	The Accountable Authority complies with all Protective Security Directions.
Policy Requirement	The NDIA shall ensure that the Accountable Authority complies with all Protective Security Directions issued under the Protective Security Policy Framework.
Requirement Type	PSPF
Priority / Criticality	Critical

REGULATORY BASIS

Obligation Reference	PSPF - 2
Linked ISM Control(s)	ISM-0714, ISM-0040
Other Standards / Frameworks	ISO/IEC 27001:2022 Cl. 5.1, 5.2; NIST SP 800-53 Rev 5 PM-1

CONTROL CLASSIFICATION

Control Category	Governance
Control Objective	Ensure the NDIA Accountable Authority complies with all whole-of-government Protective Security Directions to maintain WoAG security standards.

Requirement list with status, requirement statement, compliance status and maturity.

CTO Consulting

REGULATORY ASSESSMENT

OVERVIEW

Dashboard

Organisations

Discover obligations

REGISTER

Obligations

Policy requirements

Traceability

Register explorer

ASSURANCE

Control assessment

Assessment report

Regulatory calendar

AUTHORING

Policy author

AI research: rules engine

© CTO Consulting · ctoconsulting.com.au

ORGANISATION

National Insurance Disability Agency

+ New organisation

CONTROL ASSESSMENT

Assess controls — NDIA

Assess each policy requirement and its mapped controls: compliance status, maturity, design and operating effectiveness, control tests, evidence, findings and remediation.

View report

8 of 240 assessed (3%) · compliance score 75%

Compliant 4

Largely compliant 2

Partially compliant 1

Non-compliant 1

Not assessed 232

Search...

All policies

All statuses

Compliance with WoAG Protective Security Directions

NDIA-ICT-GOV-001 · Critical · Compliant

Accountable Authority Ministerial Accountability for Protective Security

NDIA-ICT-GOV-002 · Critical · Partially compliant

Accountable Authority Responsibility for Security Risk Management

NDIA-ICT-GOV-003 · Critical · Compliant

Appointment of Chief Security Officer

NDIA-ICT-GOV-004 · Critical · Largely compliant

CSO Seniority and Minimum Security Clearance

NDIA-ICT-GOV-005 · High · Non-compliant

CSO Accountability to Accountable Authority

NDIA-ICT-GOV-006 · High · Compliant

NDIA-ICT-GOV-002 · ICT GOVERNANCE POLICY

Accountable Authority Ministerial Accountability for Protective Security

Critical Governance PSPF - 6

← Previous

2 / 240

Next →

The NDIA shall ensure that the Accountable Authority is answerable to the responsible Minister for the entity's protective security posture and performance.

Control objective: Establish clear lines of ministerial accountability for the NDIA's protective security, ensuring executive responsibility is transparent and enforced.

Show implementation guidance, verification method and RACI

1 Compliance status

Compliant

Largely compliant

Partially compliant

Non-compliant

Not applicable

Not assessed

2 Maturity and effectiveness

Current maturity

Target maturity

Design effectiveness

Operating effectiveness

13. Control assessment (2 of 2)

Control testing, evidence checklist, findings and remediation.

CTO Consulting
REGULATORY
ASSESSMENT

OVERVIEW

- Dashboard
- Organisations
- Discover obligations

REGISTER

- Obligations
- Policy requirements
- Traceability
- Register explorer

ASSURANCE

- Control assessment
- Assessment report
- Regulatory calendar

AUTHORING

- Policy author

AI research: rules engine
© CTO Consulting · ctoconsulting.com.au

ORGANISATIONNational Insurance Disability Agency

+ New organisation

CISO Capability, Experience and Minimum Security Clearance

NDIA-ICT-GOV-008 · High · Largely compliant

CISO Accountability for Cyber Security Risks

NDIA-ICT-GOV-009 · Critical · Not assessed

3Control testing0 of 6 controls assessed

ISM CONTROL

ISM-0714

Not assessed

ISM CONTROL

ISM-0716

Not assessed

PROCEDURAL CONTROL

Document accountability arrangements in security governance framework.

Not assessed

PROCEDURAL CONTROL

Brief Minister on significant security events as required.

Not assessed

PROCEDURAL CONTROL

Include protective security in annual ministerial reporting.

Not assessed

PROCEDURAL CONTROL

Maintain records of ministerial briefings.

Not assessed

4Evidence0 of 2 artefacts provided

☐ Annual protective security report submitted to Minister

Reference / location

☐ record of ministerial briefings on security matters

Reference / location

Evidence notes

Documents reviewed, interviews held, samples tested...

5Findings and remediation

Finding

Recommendation

14. Assessment report (continued 1/2)

Formal report: executive summary, results by policy, heatmap, findings, remediation plan and detailed results. Print/PDF, Word, Excel and CSV.

CTO CONSULTING

Regulatory Compliance Assessment Report

National Insurance Disability Agency

Scope: All target policies · Report date: 2026-09-29 · Requirements in scope: 240

1. Executive summary

75%

Compliance score

8 of 240 policy requirements (3%) have been assessed, with an overall compliance score of 75%. 4 are compliant, 2 largely compliant, 1 partially compliant and 1 non-compliant. 4 findings were raised (1 critical risk, 1 high risk, 2 medium risk).

Compliant 4

Largely compliant 2

Partially compliant 1

Non-compliant 1

Not assessed 232

2. Scope and methodology

The assessment covers 240 policy requirements consolidated from 3,634 obligations across 105 applicable legislative, regulatory and standards sources. Each requirement was assessed for compliance status, capability maturity, design and operating effectiveness of its controls, and supporting evidence.

Compliant	100%	0 — Non-existent	No control in place.
Largely compliant	75%	1 — Initial	Ad hoc, undocumented and person-dependent.
Non-compliant	0%	4 — Managed	Measured, monitored and reported.
Not applicable	Excluded	5 — Optimised	Continuously improved using metrics and lessons learned.

3. Results by target policy

POLICY	REQUIREMENTS	ASSESSED	SCORE	STATUS DISTRIBUTION
ICT Acceptable Use Policy NDIA-POL-ICT-AUP-001	25	0	—	
ICT Agency and Scheme Applications NDIA-POL-ICT-ASA-001	12	0	—	
ICT Authorisation and Accrediation Policy NDIA-POL-ICT-AAP-001	16	0	—	
ICT Digital Experience Policy NDIA-POL-ICT-DEP-001	16	0	—	
ICT Governance Policy NDIA-POL-ICT-GOV-001	34	8	75%	
NDIA ICT Cyber Security Policy NDIA-POL-ICT-CYB-001	13	0	—	
NDIA ICT Disaster Recovery Policy NDIA-POL-ICT-DRP-001	11	0	—	
NDIA ICT Identity Management Policy NDIA-POL-ICT-IDM-001	18	0	—	
NDIA ICT Infrastructure Management Policy NDIA-POL-ICT-INF-001	16	0	—	
NDIA ICT Insider Threat and Risk Policy	18	0	—	

CTO Consulting
REGULATORY
ASSESSMENT

OVERVIEW

Dashboard

Organisations

Discover obligations

REGISTER

Obligations

Policy requirements

Traceability

Register explorer

ASSURANCE

Control assessment

Assessment report

Regulatory calendar

AUTHORING

Policy author

ORGANISATION

National Insurance Disability Agency

+ New organisation

14. Assessment report (continued 2/2)

AI research: rules engine
© CTO Consulting · ctoconsulting.com.au

NDIA-POL-ICT-INT-001								
NDIA ICT Integration Policy		16	0	—				
NDIA-POL-ICT-ING-001								
NDIA ICT Service Management Policy		15	0	—				
NDIA-POL-ICT-SVM-001								
NDIA ICT Technology Enabled Projects Policy		15	0	—				
NDIA-POL-ICT-TEP-001								
NDIA ICT Technology Portfolio Planning Policy		15	0	—				
NDIA-POL-ICT-TPP-001								
4. Priority × compliance heatmap								
PRIORITY	COMPLIANT	LARGELY COMPLIANT	PARTIALLY COMPLIANT	NON-COMPLIANT	NOT APPLICABLE	NOT ASSESSED		
Critical	3	1	1	0	0		120	
High	1	1	0	1	0		106	
Medium	0	0	0	0	0		6	
5. Capability maturity								
POLICY	ASSESSED	AVERAGE CURRENT	AVERAGE TARGET	GAP				
ICT Governance Policy	8	2.0	3.0	1.0				
6. Key findings								
REQUIREMENT	STATUS	RISK	FINDING	RECOMMENDATION	OWNER / DUE			
NDIA-ICT-GOV-005 CSO Seniority and Minimum Security Clearance	Non-compliant	Critical	CSO clearance level below the PSPF minimum.	Commence NV1 clearance process for the CSO.	— 2026-12-01			
NDIA-ICT-GOV-002 Accountable Authority Ministerial Accountability for Protective Security	Partially compliant	High	Accountable Authority acknowledgement of the latest PSPF Directions not recorded.	Brief the CEO and record signed acknowledgement.	— 2026-10-30			
NDIA-ICT-GOV-004 Appointment of Chief Security Officer	Largely compliant	Medium	CSO appointment documented but delegation instrument is out of date.	Update delegation instrument.	— 2026-11-15			
NDIA-ICT-GOV-008 CSO Capability, Experience and Minimum Security Clearance	Largely compliant	Medium	—	—	—			
7. Remediation plan								
DUE	REQUIREMENT	ACTION	OWNER	STATUS				
2026-10-30	NDIA-ICT-GOV-002 — Accountable Authority Ministerial Accountability for Protective Security	Brief the CEO and record signed acknowledgement.		Open				
2026-11-15	NDIA-ICT-GOV-004 — Appointment of Chief Security Officer	Update delegation instrument.		Open				
2026-12-01	NDIA-ICT-GOV-005 — CSO Seniority and Minimum Security Clearance	Commence NV1 clearance process for the CSO.		Open				
8. Detailed control results								
REQUIREMENT	POLICY	PRIORITY	STATUS	MATURITY	DESIGN / OPERATING	CONTROLS	EVIDENCE	
NDIA-ICT-GOV-001 Compliance with WoAG Protective Security Directions	ICT Governance Policy	Critical	Compliant	2 → 3	Not tested / Not tested	0/6 implemented	0/2	

15. Traceability — trace explorer

Obligations → requirement → controls → evidence → roles → policy, lifecycle and assessment.

CTO Consulting
REGULATORY
ASSESSMENT

OVERVIEW

- Dashboard
- Organisations
- Discover obligations

REGISTER

- Obligations
- Policy requirements
- Traceability
- Register explorer

ASSURANCE

- Control assessment
- Assessment report
- Regulatory calendar

AUTHORING

- Policy author

TRACEABILITY

Traceability — NDIA

End-to-end traceability from obligation sources to policy requirements, controls, evidence, roles, target policies, exemptions and assessment results.

Trace explorerTraceability matrixCoverage heatmap

Find a requirement...NDIA-ICT-GOV-001 — Compliance with WoAG Protective Security Directions

Assess

OBLIGATIONS1POLICY REQUIREMENTCONTROLS6EVIDENCE REQUIRED2ROLES (RACI)POLICY, LIFECYCLE & ASSURANCE

Protective Security

NDIA-ICT-GOV-001

ISM control

Signed Accountable

Accountable

Trust policy

ORGANISATIONNational Insurance Disability Agency

+ New organisation

The NDIA shall ensure that the Accountable Authority complies with all Protective Security Directions issued under the Protective Security Policy Framework.

CriticalPSPF

Control objective

Ensure the NDIA Accountable Authority complies with all whole-of-government Protective Security Directions to maintain WoAG security standards.

Threat / risk

Non-compliance with PSPF Directions; regulatory breach; reputational and legal risk to the NDIA

Risk if unmet: Critical

ISM-0040

Procedural control

Monitor PSPF Directions published by Department of Home Affairs.

Procedural control

Brief Accountable Authority on new Directions.

Procedural control

Update NDIA security policies to reflect Directions.

Procedural control

Report compliance in annual report.

Control category

Governance

ISO/IEC 27001:2022 Cl. 5.1, 5.2; NIST SP 800-53 Rev 5 PM-1

annual protective security report

Verification

Annual protective security report review; independent IRAP assessment; internal audit

Audit: Annual

Responsible

Chief Security Officer (CSO); Chief Information Security Officer (CISO)

Consulted

General Counsel; Group Manager, Technology; NDIA Security Team

Informed

All NDIA Branch Managers; Department of Home Affairs

Owner (SME)

Chief Security Officer (CSO)

Security Roles

Assessment

Compliant

Exceptions

No — Accountable Authority (subject to PSPF contingency provisions)

Related documents

NDIA Cyber Security Policy; NDIA Risk Management Policy; NDIA Information Security Policy

PSPF Annual Reporting Guidance (Dept of Home Affairs); NDIA Security Governance Framework

Review

Annual - Active

Last reviewed 2026-05-06

Obligations mapped to NDIA-ICT-GOV-001

ID	SOURCE	REFERENCE	DESCRIPTION
PSPF - 2	Protective Security Policy Framework (PSPF) Release 2025	01. WoAG Protective Security Roles	The Accountable Authority complies with all Protective Security Directions.

At research: rules engine

© CTO Consulting · ctoconsulting.com.au

The source workbook's per-policy traceability and consolidation worksheets are available verbatim in the Register explorer.

16. Traceability — matrix

Every obligation-to-requirement link with controls, evidence, accountable role, audit frequency and status.

CTO Consulting
REGULATORY
ASSESSMENT

OVERVIEW

- Dashboard
- Organisations
- Discover obligations

REGISTER

- Obligations
- Policy requirements
- Traceability
- Register explorer

ASSURANCE

- Control assessment
- Assessment report
- Regulatory calendar

AUTHORING

- Policy author

AI research: rules engine
© CTO Consulting - ctoconsulting.com.au

ORGANISATIONNational Insurance Disability Agency

+ New organisation

TRACEABILITY

Traceability — NDIA

End-to-end traceability from obligation sources to policy requirements, controls, evidence, roles, target policies, exemptions and assessment results.

Trace explorerTraceability matrixCoverage heatmap

Search obligations, requirements, ISM controls...

All target policies

Export full matrix (CSV)

OBLIGATION	REQUIREMENT	TARGET POLICY	CONTROLS	EVIDENCE	ACCOUNTABLE	AUDIT	STATUS
ARC-04 Archives Act 1983 Archives Act 1983 - Agency responsibilities	NDIA-ICT-AAP-014 Records, metadata, retention and secure disposal	ICT Authorisation and Accrediatiobn Policy	Legal & Compliance Relevant ISM information handlin...	Records assessment; metadata schema; retention schedule;...	Records Manager / Information Owner	Annual	Not a
ARC-05 Archives Act 1983 Archives Regulations - Written information...	NDIA-ICT-AAP-014 Records, metadata, retention and secure disposal	ICT Authorisation and Accrediatiobn Policy	Legal & Compliance Relevant ISM information handlin...	Records assessment; metadata schema; retention schedule;...	Records Manager / Information Owner	Annual	Not a
ARC-06 Archives Act 1983 NAA guidance - Data and datasets are...	NDIA-ICT-AAP-004 System definition, boundary, classification and criticality	ICT Authorisation and Accrediatiobn Policy	Administrative ISM-0041, ISM-1739	SSP; architecture diagrams; data flow maps; asset inventory; data...	System Owner	Triggered	Not a
ARC-07 Archives Act 1983 NAA guidance - Identify digital records in...	NDIA-ICT-AAP-004 System definition, boundary, classification and criticality	ICT Authorisation and Accrediatiobn Policy	Administrative ISM-0041, ISM-1739	SSP; architecture diagrams; data flow maps; asset inventory; data...	System Owner	Triggered	Not a
ARC-08 Archives Act 1983 NAA Information	NDIA-ICT-AAP-014 Records, metadata, retention and secure	ICT Authorisation and	Legal & Compliance Relevant ISM information handlin...	Records assessment; metadata schema; retention schedule;...	Records Manager / Information	Annual	Not a

17. Traceability — coverage heatmap (continued 2/2)

[illegible]

18. Policy author

Automatically drafted policy following the template; every section editable; Word and PDF export.

CTO Consulting
REGULATORY
ASSESSMENT

OVERVIEW

- Dashboard
- Organisations
- Discover obligations

REGISTER

- Obligations
- Policy requirements
- Traceability
- Register explorer

ASSURANCE

- Control assessment
- Assessment report
- Regulatory calendar

AUTHORING

- Policy author

AI research: rules engine
© CTO Consulting · ctoconsulting.com.au

ORGANISATIONNational Insurance Disability Agency

+ New organisation

POLICY AUTHOR

Author policy documents

Automatically drafts a complete policy from the organisation's policy requirements, obligations, RACI, evidence and review attributes, following your policy template. Edit any section in place.

Download WordPrint / PDF

Policy

Target policy

ICT Acceptable Use Policy (25) ✓

Regenerate

Regenerating rebuilds all sections from the current register and keeps the document details. Edits are saved automatically.

Template

CTO Consulting standard policy template

Upload an example policy (.docx). Its heading structure becomes the template: matching headings are populated automatically; other headings are kept as placeholders.

Upload .docx template

1. Purpose

2. Scope

3. Policy statement

4. Legislative and regulatory context

5. Policy requirements

6. Roles and responsibilities

7. Exceptions and exemptions

8. Compliance, monitoring and reporting

9. Breaches of this policy

10. Related documents

OFFICIAL

NATIONAL INSURANCE DISABILITY AGENCY

ICT Acceptable Use Policy

NDIA-POL-ICT-AUP-001 · Version 0.1 (Draft) · Draft for consultation

Policy owner	CISO
Approved by	CISO
Effective date	2026-09-29
Next review	2027-09-29
Prepared by	CTO Consulting

1. Purpose

The purpose of the ICT Acceptable Use Policy is to set clear expectations for the authorised, lawful, secure and respectful use of ICT resources, information and accounts.

This policy gives effect to 30 legislative, regulatory and standards sources applicable to National Insurance Disability Agency, consolidated into 25 policy requirements. It establishes what NDIA must do; supporting standards, procedures and guidelines describe how.

2. Scope

This policy applies to all NDIA personnel (including employees, contractors, consultants and third parties acting on behalf of NDIA), and to all information, ICT systems, services and

19. Policy author — policy requirements section

Numbered policy clauses generated from the requirements, with requirement ID, priority and regulatory basis.

CTO Consulting
REGULATORY
ASSESSMENT

OVERVIEW

- Dashboard
- Organisations
- Discover obligations

REGISTER

- Obligations
- Policy requirements
- Traceability
- Register explorer

ASSURANCE

- Control assessment
- Assessment report
- Regulatory calendar

AUTHORING

- Policy author

AI research: rules engine
© CTO Consulting · ctoconsulting.com.au

ORGANISATIONNational Insurance Disability Agency

+ New organisation

5. Policy requirements

5.1 Authorised, lawful and proper use of NDIA ICT

5.1.1 Authorised use of NDIA ICT.

Users must use NDIA ICT for authorised NDIA work. Limited personal use is permitted only when it is lawful, reasonable, low risk, does not interfere with work, and complies with NDIA policies, lawful directions and applicable laws.

Requirement NDIA-ICT-AUP-001 · High · Mandatory · Basis: APS-VCE-01: Public Service Act 1999 s 13 and APSC Code of Conduct guidance, APS-VCE-02: Public Service Act 1999 s 13(4)-(5); APSC Code of Conduct elements, APS-EPC-01: Public Service Act 1999 ss 10, 10A and 13; APSC APS Values guidance, NDIS-04: NDIS Act ss 118 and 124 · Agency and Board functions; s 169 · staff engaged under Public Service Act. PGPA-01: PGPA Act governance and use of public resources obligations, including duties of accountable authorities and officials. PSA-01: Public Service Act 1999 s 13. PSA-02: Public Service Act 1999 s 13(8).

5.2 Respectful, lawful and inclusive digital conduct

5.2.1 Respectful, lawful and inclusive digital conduct.

Users must not use NDIA ICT, email, messaging, meetings, collaboration tools or social media to discriminate, bully, harass, threaten, intimidate, humiliate, abuse, victimise, sexually harass, coerce, or publish hateful, hostile or offensive material.

Requirement NDIA-ICT-AUP-002 · Critical · Mandatory · Basis: ADA-01: Objects and unlawful discrimination provisions, including ss 3, 14-18. APS-VCE-03: APS Values and Code of Conduct guidance; Public Service Act ss 10 and 13. APS-VCE-05: Public Service Act 1999 s 13(3); APS Employment Principles and Code guidance. AHRC-01: AHRC Act functions relating to human rights, equal opportunity in employment and unlawful discrimination. CCA-02: Criminal Code, Part 10.6 telecommunications offences, including carriage service offences. DDA-01: Disability Discrimination Act 1992, ss 5-6, 15, 24 and 29. DDA-03: DDA harassment and discrimination provisions. FWA-01: Fair Work Act workplace protections, anti-bullying and sexual harassment provisions. FWA-02: Fair Work Act general protections and workplace rights provisions. OSA-01: Online Safety Act schemes for cyber-bullying, cyber-abuse and intimate image material. PSA-03: Public Service Act 1999 s 13(3). RDA-01: Racial Discrimination Act 1975, including s 9 and related unlawful discrimination provisions. RDA-02: Racial Discrimination Act 1975, racial hatred provisions including Part IIA and s 18C. SDA-01: Sex Discrimination Act 1984 discrimination provisions, including ss 5-7 and related provisions. SDA-02: Sex Discrimination Act 1984 sexual harassment, harassment and hostile workplace provisions, including ss 28A and 28AA. SDA-03: Sex Discrimination Act 1984 victimisation provisions.

5.3 Accessible and inclusive digital content and communications

5.3.1 Accessible and inclusive digital content.

Users must create, publish and send NDIA digital information in accessible, inclusive and respectful formats. Where a person needs a different communication mode, users must provide an approved accessible alternative or reasonable adjustment.

Requirement NDIA-ICT-AUP-003 · High · Mandatory · Basis: ADA-02: Services, facilities and administration of Commonwealth laws or programs, including ss 28, 31 and 32. AHRC-03: AHRC Act objects and complaint framework, read with Commonwealth anti-discrimination laws. DDA-02: DDA provisions on goods, services, facilities and Commonwealth programs; reasonable adjustment principles. DDA-04: DDA service and facilities obligations, read

20. Regulatory calendar — month

Statutory reporting, commencements, reviews, audits, exemptions and remediation; .ics export.

CTO Consulting

REGULATORY ASSESSMENT

OVERVIEW

Dashboard

Organisations

Discover obligations

REGISTER

Obligations

Policy requirements

Traceability

Register explorer

ASSURANCE

Control assessment

Assessment report

Regulatory calendar

AUTHORING

Policy author

AI research: rules engine

© CTO Consulting · ctoconsulting.com.au

ORGANISATION

National Insurance Disability Agency

+ New organisation

ISM quarterl...

Control audi...

Requiremen...

Requiremen...

21	22	23	24	25	26	27
28	29	30	1	2	3	4
5	6	7	8	9	10	11

CIRMP annu...

Commonwe...

NAA Check...

PSPF annual...

2026-10-28

FOI statistics return to OAIC

Event-driven deadlines

Triggered by an incident or event rather than a date

Assess suspected eligible data breach

Within 30 days

Notifiable Data Breaches Scheme

Report a ransomware or cyber extortion payment

Within 72 hours

Cyber Security Act 2024 and Cyber Security (Ransomware Payment Reporting) Rules 2025

Report a critical cyber security incident (significant impact)

Within 12 hours

Security of Critical Infrastructure Act 2018

Refer serious or systemic corrupt conduct

As soon as reasonably practicable

National Anti-Corruption Commission Act 2022 and mandatory referral obligations

Dates marked *indicative* are set by the regulator each cycle; confirm them before relying on them. Review and audit dates come from each requirement's Review Frequency, Audit Frequency and Last Reviewed attributes.

21. Regulatory calendar — agenda (continued 1/2)

Upcoming 18 months by month, with indicative dates flagged.

CTO Consulting

REGULATORY ASSESSMENT

OVERVIEW

Dashboard

Organisations

Discover obligations

REGISTER

Obligations

Policy requirements

Traceability

Register explorer

ASSURANCE

Control assessment

Assessment report

Regulatory calendar

AUTHORING

Policy author

AI research: rules engine

© CTO Consulting · ctoconsulting.com.au

ORGANISATION

National Insurance Disability Agency

+ New organisation

REGULATORY CALENDAR

Upcoming obligations — NDIA

Statutory reporting and commencement dates for the organisation's applicable sources, plus requirement reviews, control audits, exemption expiries and remediation due dates from the register and assessment.

Next 18 months

Today

Month

Agenda

Reporting (31)

Commencement (2)

Review (45)

Audit (95)

Exemption (4)

Remediation (3)

September 2026

30 Sept

Commonwealth fraud and corruption census return (AIC)

Commonwealth Fraud and Corruption Control Framework 2024

Reporting

Indicative

30 Sept

NAA Check-up information management survey

Archives Act 1983

Reporting

Indicative

30 Sept

PSPF annual security report to Home Affairs and Minister

Protective Security Policy Framework (PSPF) Release 2025

Reporting

Indicative

October 2026

15 Oct

Annual report to responsible Minister (PGPA Act s46)

PGPA Act 2013

Reporting

15 Oct

Quarterly external ASV vulnerability scan (PCI DSS 11.3.2)

PCI DSS v4.0.1

Audit

Indicative

28 Oct

FOI statistics return to OAIC

Freedom of Information Act 1982

Reporting

Indicative

30 Oct

Remediation due — NDIA-ICT-GOV-002: Accountable Authority Ministerial Accountability for Protective Security

Brief the CEO and record signed acknowledgement.

Remediation

31 Oct

Quarterly performance report to Disability Reform Ministerial Council

NDIS Act 2013

Reporting

Indicative

November 2026

15 Nov

Control audit — ICT Acceptable Use Policy (5 requirements)

Control verification due under the requirement's Audit Frequency.

Audit

15 Nov

Remediation due — NDIA-ICT-GOV-004: Appointment of Chief Security Officer

Update delegation instrument.

Remediation

19 Nov

Control audit — ICT Authorisation and Accrediation Policy (6 requirements)

Control verification due under the requirement's Audit Frequency.

Audit

30 Nov

Annual PCI DSS assessment (ROC / SAQ and AOC)

PCI DSS v4.0.1

Audit

Indicative

December 2026

01 Dec

Remediation due — NDIA-ICT-GOV-005: CSO Seniority and Minimum Security Clearance

Commence NV1 clearance process for the CISO.

Remediation

02 Dec

Control audit — ICT Agency and Scheme Applications (7 requirements)

Control verification due under the requirement's Audit Frequency.

Audit

04 Dec

Control audit — ICT Digital Experience Policy (4 requirements)

Control verification due under the requirement's Audit Frequency.

Audit

Export to Outlook / Google (.ics)

Overdue (1)

2026-07-14

Exemption review — NDIA-EXM-001: ASD Temporary Mitigations for Legacy IT

Next 30 days

2026-09-30

Commonwealth fraud and corruption census return (AIC)

2026-09-30

NAA Check-up information management survey

2026-09-30

PSPF annual security report to Home Affairs and Minister

2026-10-15

Annual report to responsible Minister (PGPA Act s46)

2026-10-15

Quarterly external ASV vulnerability scan (PCI DSS 11.3.2)

2026-10-28

FOI statistics return to OAIC

Event-driven deadlines

Triggered by an incident or event rather than a date

Assess suspected eligible data breach

Within 30 days

Notifiable Data Breaches Scheme

Report a ransomware or cyber extortion payment

Within 72 hours

Cyber Security Act 2024 and Cyber Security (Ransomware Payment Reporting) Rules 2025

Report a critical cyber security incident (significant impact)

Within 12 hours

Security of Critical Infrastructure Act 2018

Refer serious or systemic corrupt conduct

As soon as reasonably practicable

National Anti-Corruption Commission Act 2022 and mandatory referral obligations

Dates marked *indicative* are set by the regulator each cycle; confirm them before relying on them. Review and audit dates come from each requirement's Review Frequency, Audit Frequency and Last Reviewed attributes.

21. Regulatory calendar — agenda (continued 2/2)

	04 Dec	Control audit — ICT Digital Experience Policy (4 requirements) Control verification due under the requirement's Audit Frequency.	Audit	
	06 Dec	Control audit — NDIA ICT Cyber Security Policy (5 requirements) Control verification due under the requirement's Audit Frequency.	Audit	

22. Register explorer

All 53 worksheets of the uploaded register, loaded verbatim and searchable.

CTO Consulting
REGULATORY
ASSESSMENT

OVERVIEW

- Dashboard
- Organisations
- Discover obligations

REGISTER

- Obligations
- Policy requirements
- Traceability
- Register explorer

ASSURANCE

- Control assessment
- Assessment report
- Regulatory calendar

AUTHORING

- Policy author

AI research: rules engine
© CTO Consulting - ctoconsulting.com.au

ORGANISATIONNational Insurance Disability Agency

+ New organisation

REGISTER EXPLORER

NDIA_ICT_Policy_Requirements_Register_v0.48.xlsx

Every worksheet of the uploaded policy requirements register, loaded verbatim against the National Insurance Disability Agency (53 worksheets).

Export sheet (CSV)

REQUIREMENT REGISTERS

Requirements240

Requirements Capture - GOV34

Requirements Register- AUP25

Requirements Register - AAP16

Requirements Register - ASA12

Requirements Register - DEP16

Requirements Register - DRP11

Requirements Register - CYB13

Requirements Register - ING16

Requirements Register - SVM15

Requirements Register - INF16

Requirements Register - TPP15

Requirements Register - TEP15

Requirements Register - INT18

Requirements Register - IDM18

OBLIGATIONS3634

Requirements

IT Policy Requirements Capture Register — NDIA ICT Policy Framework

Search this sheet...

REQUIREMENT ID	TARGET POLICY TITLE	POLICY NUMBER	POLICY DOMAIN	POLICY SECTION / CLAUSE	REQUIREMENT TITLE
NDIA-ICT-GOV-001	ICT Governance Policy	NDIA-POL-ICT-GOV-001	Strategy, Architecture, and Governance	WoAG Protective Security Roles	Compliance with WoAG Protective Security...
NDIA-ICT-GOV-002	ICT Governance Policy	NDIA-POL-ICT-GOV-001	Strategy, Architecture, and Governance	Entity Protective Security Roles and...	Accountable Authority Ministerial...
NDIA-ICT-GOV-003	ICT Governance Policy	NDIA-POL-ICT-GOV-001	Strategy, Architecture, and Governance	Entity Protective Security Roles and...	Accountable Authority Responsibility fo...
NDIA-ICT-GOV-004	ICT Governance Policy	NDIA-POL-ICT-GOV-001	Strategy, Architecture, and Governance	Entity Protective Security Roles and...	Appointment of Chief Security Officer
NDIA-ICT-GOV-005	ICT Governance Policy	NDIA-POL-ICT-GOV-001	Strategy, Architecture, and Governance	Entity Protective Security Roles and...	CSO Seniority and Minimum Security Clearance
NDIA-ICT-GOV-006	ICT Governance Policy	NDIA-POL-ICT-GOV-001	Strategy, Architecture, and Governance	Entity Protective Security Roles and...	CSO Accountability to Accountable...
NDIA-ICT-GOV-007	ICT Governance Policy	NDIA-POL-ICT-GOV-001	Strategy, Architecture, and Governance	Entity Protective Security Roles and...	Appointment of Chief Information Security Officer

23. Mobile view

Responsive layout at phone width.

